

policy based and hence will have the same amount of access/facilities for any login.

Moreover, the security of the second Web app's login is not guaranteed. To overcome this, there was a minor change done in the bypass login, whereby there is an extra parameter passed from the first Web app to the second one, which is the key to access the second Web app. The drawback in this process is that there is always the dependency of the key parameter, and the second Web app has to be always called from the first one (scheduled or automated tasks cannot be run).

Web service call: This is generally used when the second and subsequent Web apps expose certain Web services, and the first Web app invokes calls to these Web apps through these Web service calls. The problem in this feature is that the developer is more dependent on the structure of the input/output of the Web service and is bound to handle all requests through them only.

What is single sign-on?

Though a bypass login and Web service call provide facilities to skip subsequent logins to different Web apps, there are some drawbacks in their overall architecture, as seen earlier. If we first understand the need for using multiple Web apps, we can easily grasp why a single sign-on is required.

Consider a complex enterprise Web app for a textile firm which involves various operations like ordering, samples, mailing, designing, etc. If we develop a single Web app to cater to all these needs, then maintaining it will be highly complex.

A service provider company that designs software for different industries will be always interested in developing individual modules and integrating the required pieces when desired. This will help in the sizing of the module and its maintenance. The process and benefits of this approach are as follows:

- Usage of different technologies in different modules, depending on what the module is required to do.
- Easy usage and faster work due to the delegation of several actions in parallel across different modules.
- Allows for the reuse of the modules for different Web solutions, as and when required.

Now when we think of a single sign-on facility for the above case, it's very obvious that a bypass login or a Web service call cannot be advantageous in such real-time situations; in fact, they may further complicate the solution as it grows bigger in order to integrate more and more modules.

In short, single sign-on is a facility to skip or use the login information used in the first Web app for all subsequent Web apps without popping out the login screen for each one. There are many standard technologies and techniques used for SSO in the industry, and many of them are open source or freeware. We will discuss some of the most popular and robust technologies here.

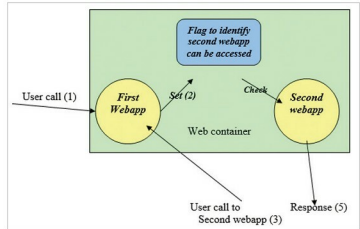


Figure 1: Bypass login

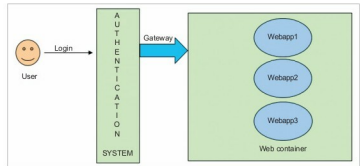


Figure 2: Single sign-on

But before delving further into the topic, let me share the terms that are going to be used hereafter, along with their meaning and usage.

LDAP – Lightweight Directory Access Protocol: This is a protocol used commonly in Web apps for looking up certain information from the servers; it is widely used in mail servers.

Datastore: This is the store in LDAP that keeps authentication and other access related data.

Directory server: This provides the datastore for LDAP and supports many protocols internally.

Authentication: This is a piece of information that is verified to certify or deny access, like the user name/password.

Realms: This is a kind of group or system to provide facilities for authentication. It offers a lot of features for configuration like policy setting, access control, privileges for realms, etc, which can be easily configured for role based access for different groups and logins. There are two configurations in OpenSSO -- Default and New Config. The Default configuration is easy. The advantage is that it can be customised later and hence is meant for basic or first-time users. New Config, however, is meant for advanced users, and there may be some problems with getting the directory service port or cookie domain if the user doesn't know each configuration setting and doesn't provide them.

OAuth

One of the most popular and commonly used single sign-on solutions for Java Web apps is OAuth or OAuth 2.0, as the